



SNOWBE ONLINE Policy# Password Standard

Your name: Sean Cardona

<TEMPLATE> - Version # 1

DATE: 10/27/2024

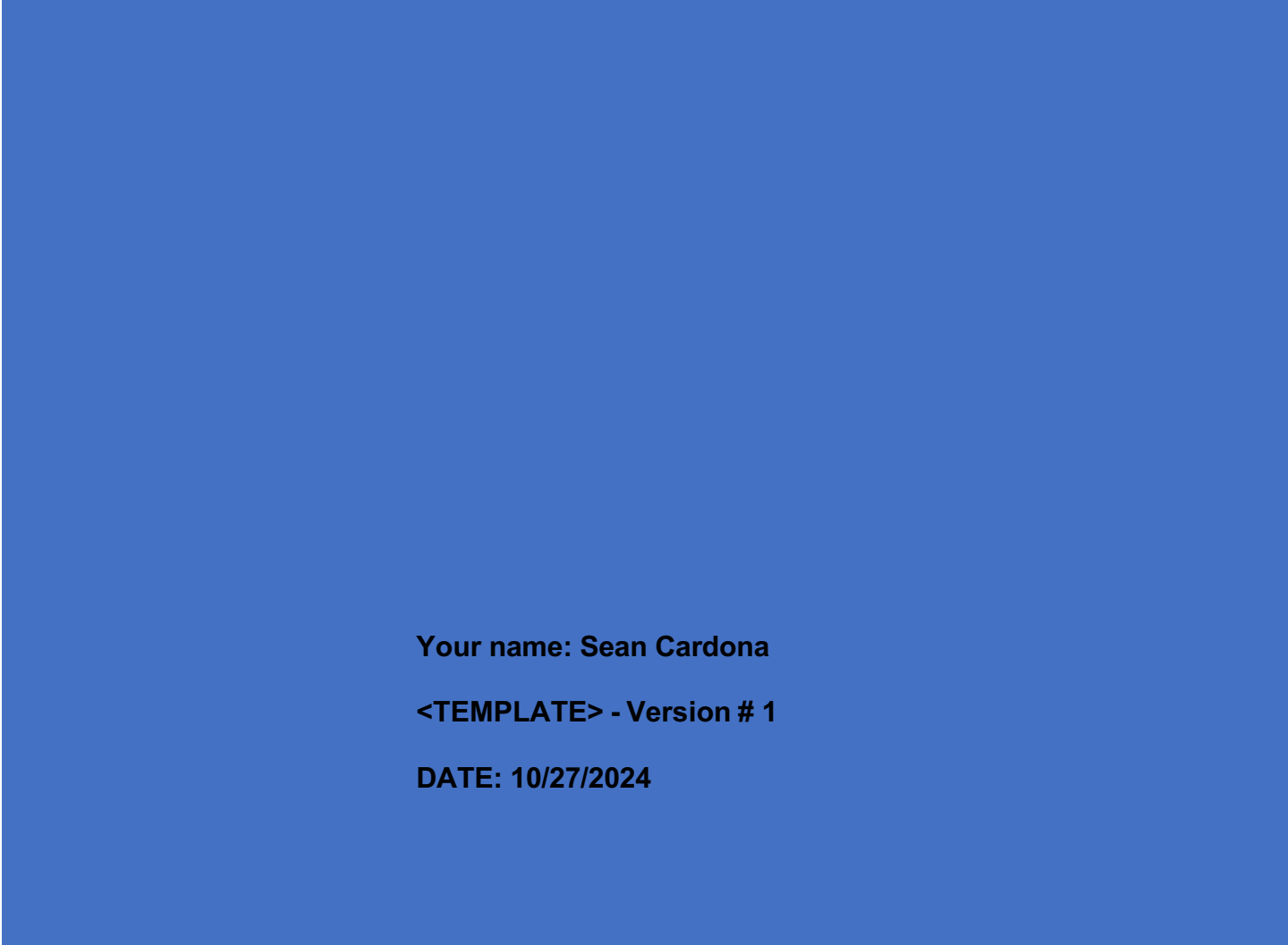


Table of Contents

PURPOSE.....2

SCOPE.....2

DEFINITIONS2

ROLES & RESPONSIBILITIES2

POLICY3

EXCEPTIONS/EXEMPTIONS5

ENFORCEMENT5

VERSION HISTORY TABLE5

CITATIONS.....7

Purpose

To provide guidance and direction to our employees about password creation, use and account management. Passwords are key to keeping your account secure and are the first line of defense to protect our sensitive company information. This policy covers both user accounts and system accounts managed by system administrators

Scope

This policy will apply to all employees, contractors, and third party users that can access organizational systems, applications, and networks.

Definitions

- Multi-Factor Authentication (MFA)
 - Security process that uses two or more verification methods to grant access.
- Account Lockout
 - Security measures are taken that temporarily disable accounts after they fail to login a certain amount of times. This protects accounts from brute force attempts.

Roles & Responsibilities

- Employees and System Uses
 - Adhere to the password policy, by using password requirements for the creation of a complex password
 - Use Multi-Factor Authentication when handling sensitive data and avoid sharing and storing passwords in unsecure methods.

- Change passwords immediately when suspecting unauthorized access.
- IT Helpdesk
 - Help users reset passwords with secure verification methods
 - Educate fellow employees on the best password security methods.
 - Unlock accounts that have been locked out due to multiple failed attempts.
- Human resources (HR)
 - During the onboarding process, HR must ensure user complete their security training and follow password policy standards.
 - Alert IT employees of role changes, terminations, and hirings to give proper access for passwords.

Policy

- Users
 - It is our company's policy that users shall establish and maintain strong passwords to prevent malicious actors from easily guessing the password;
 - Users are directed not to reuse passwords across multiple accounts;
 - Passwords shall be created with complexity such as pass phases,

and not contain easily known or guessable elements such as names, birthdays, street addresses or sports teams;

- Passwords shall be made up of alphanumeric (a mix of numbers and letters) with special characters such as (!@#\$%^&*()_+) and a mix of upper and lowercase characters as guided by the software or hardware systems;
- Passwords shall be a minimum of 8 characters long;
- Passwords shall not be created with commonly used passwords such as Password123;
- Passwords shall not be written down on a sticky note, displayed on a public-facing screen, or placed under a keyboard;
- Passwords shall be changed periodically, as guided by the software governing the systems, using new passwords;
- For all sensitive business accounts, two-factor authentication will be enabled.
- Passwords shall not be shared with anyone. For accountability and security, each employee shall have his/her own password for each account.

- Administrators

- Limit the number of times a password can be attempted to be entered incorrectly to three or four attempts. This will prevent unauthorized individuals or programs from trying to guess passwords;
- Set passwords to expire every 90 to 120 days;
- . Evaluate the security questions for account management. Easy-to-guess security questions (i.e. “Who was your best friend in high school?”) should not be used;
- Any default passwords that come with a product should be changed during product installation;
- Use screen protection to prevent someone from peeping over the employees’ shoulders;
- Enable two-factor authentication for all sensitive accounts, especially account logins used by administrators.
- Encourage your company’s users to utilize a password manager such as 1Password to save and manage passwords;

- If a user account has been compromised instruct and follow through with users to ensure their password is immediately changed;
- Encourage users to check to see if their password and login have been compromised at “I have been pwned” - <https://haveibeenpwned.com/>;
- Instruct users that if they receive an email concerning a breach or password reset, not to click on it, but rather go directly to their account on the website.;
- As our company’s IT security POC, leverage the educational resources provided through our account at the NCSS.

Exceptions/Exemptions

Exemption request forms must be filed specifying the duration and justification/reasoning for the request and submitted to the CISO pending review. In the case of password standards, there are no exceptions or exemptions.

Enforcement

Failure to comply with this policy can lead to disciplinary action, but not limited to suspension and termination of employment.

Version History Table

Version #	Implementation Date	Document Owner	Approved By	Description
1	10/27/2024	SnowBe	Sean Cardona	A guide and standards to creating a password that will access organizational systems.

<Template Policy> – V 1.0
Status: ☒ Working Draft ☐ Approved ☐ Adopted
Document owner:
DATE

--	--	--	--	--

Citations

Cybersecurity Checklist Series Password Checklist. (n.d.). Retrieved October 28, 2024, from

https://www.healthit.gov/sites/default/files/Password_Checklist.pdf

Garcia, Mi. (2017, October 2). *Easy Ways to Build a Better*

P@\$5w0rd. NIST. <https://www.nist.gov/blogs/taking-measure/easy-ways-build-better-p5w0rd>

Home. (n.d.). National Cybersecurity Society.

<https://nationalcybersecuritysociety.org>

IBM Sterling B2B Integrator. (2022, May 11). Ibm.com.

https://www.ibm.com/support/knowledgecenter/en/SS3JSW_5.2.0/com.ibm.help.security.doc/SI_PwdPolicies.html

NIST. (2020). *NIST Special Publication 800-63B*. Nist.gov; NIST.

<https://pages.nist.gov/800-63-3/sp800-63b.html>